

1. Introduction

Web applications function as programs accessible through web browsers like Firefox, Safari, or Chrome, removing the need for installation. Examples include webmail services, online office suites, and ecommerce platforms. These applications run on remote servers, serving clients continuously.

Consider an online shopping application: it retrieves product data from a database server, managing information about products, customers, and sales. However, the extensive data stored in web applications poses security risks, making them vulnerable to exploitation.

To address these risks, many companies offer bug bounty programs, rewarding individuals who identify and report security flaws. These programs, common among tech giants like Google and Microsoft, incentivize bug discoverers based on the severity of the vulnerability.

2. Module Sections

Room progress (25%)

Woop woop! Your answer is correct

Many companies offer bug bounty programs. A bug bounty program allows the company to offer a reward for anyone who discovers a security vulnerability (weakness) in the company's systems. The main condition is that the found vulnerability is within the bug bounty scope and rules. Among many others, Google, Microsoft, and Facebook have bug bounty programs. Discovering a bug can earn you from a few hundred USD to tens of thousands of USD, depending on the severity of the vulnerability, i.e., the weakness you discovered.

Answer the questions below

What do you need to access a web application?

Browser

✓ Correct Answer

Task 2 ○ Web Application Security Risks

Task 3 ○ Practical Example of Web Application Security

Room progress (75%)

Woop woop! Your answer is correct

Don't worry if these techniques look challenging or sophisticated at first. TryHackMe has dedicated in-depth rooms to help you understand and experiment with the various attacks against web applications.

Answer the questions below

You discovered that the login page allows an unlimited number of login attempts without trying to slow down the user or lock the account. What is the category of this security risk?

Identification and Authentication Failure

✓ Correct Answer

You noticed that the username and password are sent in cleartext without encryption. What is the category of this security risk?

Cryptographic Failures

✓ Correct Answer

Task 3 ○ Practical Example of Web Application Security

I navigated to the “Your Activity” tab and changed the user’s id to different number and viewed the corresponding profiles activities. I found user with id =9 had made changes to the inventory data which I then reverted and found the flag as shown below

Room progress (75%)

Click on "View Site," and let's see this in action. You will see a page showing an Inventory Management System. If you click on the "Planned Shipments" tab, you will discover that an attacker has managed to mix things up as part of sabotage plans. Notice how they send the wrong tires to each assembly line; for instance, they assign scooter tires and motorcycle tires to bike assembly! If left unfixed, all tires will go to the wrong assembly.

We will hack the system back and undo the attacker's steps. On "Your Activity," you can see the activity of one of the users. We have reason to believe that this website has an IDOR vulnerability.

Answer the questions below

Check the other users to discover which user account was used to make the malicious changes and revert them. After reverting the changes, what is the flag that you have received?

the planned shipments. If incorrect shipments are sent, production will be delayed.

https://inventory-management.thm/activity?user_id=9

MainPlanned ShipmentsInventoryYour Activity

Inventory Management System

Your Activity



Employee Id:
9

Name:
Alya

Position:
Database Administrator

Type	Data	Action
SKU Change	Inventory SKU0257 Changed	Revert
SKU Change	Inventory SKU0522 Changed	Revert
SKU Change	Inventory SKU0524 Changed	Revert

Beginner IDOR

Room progress (75%)

Click on "View Site," and let's see this in action. You will see a page showing an Inventory Management System. If you click on the "Planned Shipments" tab, you will discover that an attacker has managed to mix things up as part of sabotage plans. Notice how they send the wrong tires to each assembly line; for instance, they assign scooter tires and motorcycle tires to bike assembly! If left unfixed, all tires will go to the wrong assembly.

We will hack the system back and undo the attacker's steps. On "Your Activity," you can see the activity of one of the users. We have reason to believe that this website has an IDOR vulnerability.

Answer the questions below

Check the other users to discover which user account was used to make the malicious changes and revert them. After reverting the changes, what is the flag that you have received?

Instructions

This inventory management system manages all the shipment. malicious users used to the planned production.

Alya fixed the Inventory Management System!



THM{IDOR_EXPLORED}

MainPlanned ShipmentsInventoryYour Activity

Inventory Management System

Your Activity



Employee Id:
9

Name:
Alya

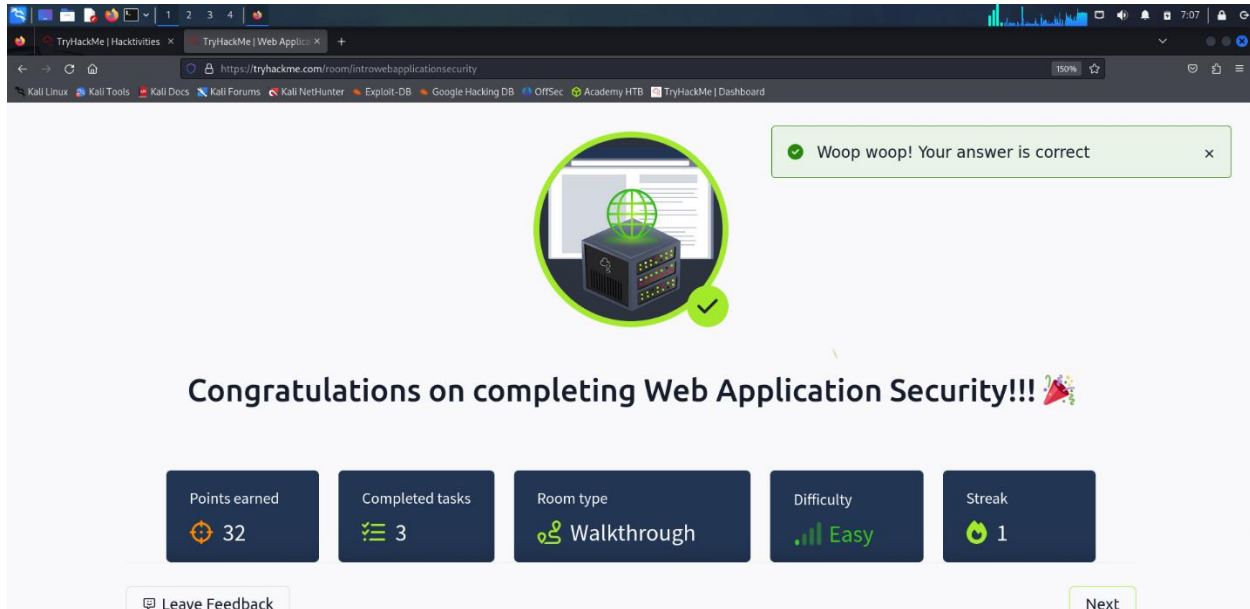
Position:
Database Administrator

Type	Data	Action
SKU Change	Inventory SKU0257 Changed	Revert
SKU Change	Inventory SKU0522 Changed	Revert
SKU Change	Inventory SKU0524 Changed	Revert

Beginner IDOR

3. Shareable Link and Final Screenshot

- Shareable link to the completed modules.
- Final screenshot showing module completion.



4. Social Media Posting

https://x.com/intent/post?url=https%3A%2F%2Ftryhackme.com%2Froom%2Fintrowebapplicationsecurity%3Futm_source%3Dtwitter%26utm_medium%3Dsocial%26utm_campaign%3Dsocial_share%26utm_content%3Droom&text=Share%20your%20achievement&via=realtryhackme&hashtags=tryhackme

https://www.facebook.com/sharer/sharer.php?u=https%3A%2F%2Ftryhackme.com%2Froom%2Fintrowebapplicationsecurity%3Futm_source%3Dfacebook%26utm_medium%3Dsocial%26utm_campaign%3Dsocial_share%26utm_content%3Droom&t=Share%20your%20achievement

https://www.linkedin.com/sharing/share-offsite/?url=https%3A%2F%2Ftryhackme.com%2Froom%2Fintrowebapplicationsecurity%3Futm_source%3Dlinkedin%26utm_medium%3Dsocial%26utm_campaign%3Dsocial_share%26utm_content%3Droom

5. Conclusion

Reflecting on this, I've learned that web applications, like webmail and e-commerce platforms, run on remote servers and serve clients continuously. These applications retrieve data from databases to manage information efficiently. However, their extensive data storage poses security risks, prompting companies to offer bug bounty programs to address vulnerabilities. This underscores the importance of vigilance and collaboration in maintaining cybersecurity.